

Journal Pre-proof

Cybersecurity risks, DevSecOps challenges, and emerging security priorities: An empirical study across Brazilian organizations

Edna Dias Canedo, Stefano Luppi Spósito, Laerte Peotta, Rafael Rabelo Nunes, Marcelo Ladeira



PII: S0167-4048(26)00202-6
DOI: <https://doi.org/10.1016/j.cose.2026.105026>
Reference: COSE 105026

To appear in: *Computers & Security*

Received date : 7 December 2025

Revised date : 17 May 2026

Accepted date : 13 June 2026

Please cite this article as: E.D. Canedo, S.L. Spósito, L. Peotta et al., Cybersecurity risks, DevSecOps challenges, and emerging security priorities: An empirical study across Brazilian organizations. *Computers & Security* (2026), doi: <https://doi.org/10.1016/j.cose.2026.105026>.

This is a PDF of an article that has undergone enhancements after acceptance, such as the addition of a cover page and metadata, and formatting for readability. This version will undergo additional copyediting, typesetting and review before it is published in its final form. As such, this version is no longer the Accepted Manuscript, but it is not yet the definitive Version of Record; we are providing this early version to give early visibility of the article. Please note that Elsevier's sharing policy for the Published Journal Article applies to this version, see: <https://www.elsevier.com/about/policies-and-standards/sharing#4-published-journal-article>. Please also note that, during the production process, errors may be discovered which could affect the content, and all legal disclaimers that apply to the journal pertain.

© 2026 Published by Elsevier Ltd.

Highlights

Cybersecurity Risks, DevSecOps Challenges, and Emerging Security Priorities: An Empirical Study Across Brazilian Organizations

Edna Dias Canedo, Stefano Luppi Spósito, Laerte Peotta, Rafael Rabelo Nunes, Marcelo Ladeira

- Provides a multidimensional analysis of organizational cybersecurity posture across risks, secure development practices, and emerging technology priorities.
- Reveals structural vulnerabilities linked to governance gaps, legacy systems, supply-chain dependencies, and insufficient vulnerability and patch management.
- Identifies critical DevSecOps barriers, including inadequate security culture, limited automation in CI/CD pipelines, and persistent issues in data protection and compliance integration.
- Maps practitioners' strategic priorities, highlighting adversarial machine learning, AI security, cloud resilience, Zero Trust, and GRC modernization as central domains for future investment.
- Offers actionable insights for capacity building, policy development, and the design of governance and training frameworks to strengthen national cybersecurity resilience.

Cybersecurity Risks, DevSecOps Challenges, and Emerging Security Priorities: An Empirical Study Across Brazilian Organizations

Edna Dias Canedo

University of Brasília (UnB), Department of Computer Science, Brasília, 70910-900, Distrito Federal, Brazil

Stefano Luppi Spósito

University of Brasília (UnB), Department of Computer Science, Brasília, 70910-900, Distrito Federal, Brazil

Laerte Peotta

University of Brasília (UnB), Department of Computer Science, Brasília, 70910-900, Distrito Federal, Brazil

Rafael Rabelo Nunes

University of Brasília (UnB), Department of Computer Science, Brasília, 70910-900, Distrito Federal, Brazil

Marcelo Ladeira

University of Brasília (UnB), Department of Computer Science, Brasília, 70910-900, Distrito Federal, Brazil

Abstract

Context: Cybersecurity has become increasingly intertwined with organizational resilience, digital transformation, and regulatory pressure. Yet, many institutions still struggle to assess their structural risks, integrate secure-by-design practices, and prepare for emerging technologies such as AI-enabled

*Corresponding author

Email addresses: `ednacanedo@unb.br` (Edna Dias Canedo), `stefanoluppi@hotmail.com` (Stefano Luppi Spósito), `laerte.melo@unb.br` (Laerte Peotta), `rafaelrabelo@unb.br` (Rafael Rabelo Nunes), `mladeira@unb.com` (Marcelo Ladeira)

cyber operations. **Goal:** This study aims to examine how Brazilian organizations perceive their cybersecurity posture across three dimensions: (i) infrastructure and governance risks, (ii) secure software development and DevSecOps challenges, and (iii) strategic priorities for emerging cybersecurity research and innovation. **Method:** We conducted a mixed-method survey with 88 practitioners from public, private, and critical infrastructure sectors. The instrument combined Likert scale assessments, multiple choice questions, and open-ended items. Quantitative data were analyzed using descriptive statistics, and qualitative responses were examined using inductive coding and thematic analysis. **Results:** Organizations report structural vulnerabilities linked to supply-chain dependencies, legacy systems, governance gaps, insider threats, and insufficient patch and vulnerability management. Challenges in secure development center on data exposure, limited security culture and training, insufficient security automation within Continuous Integration and Continuous Deployment (CI/CD) pipelines, and fragmented compliance integration. Emerging priorities include adversarial machine learning, AI security, cloud and hybrid architecture protection, cyber resilience, Governance, Risk, and Compliance (GRC) modernization, and Zero Trust adoption. **Conclusion:** Findings reveal systemic cybersecurity weaknesses and uneven DevSecOps maturity across sectors, underscoring the need for stronger governance, continuous workforce development, and resilience oriented security architectures. The study also identifies strategic research directions particularly in AI security, supply-chain defense, and cloud resilience that can guide national cybersecurity capacity building and policy making initiatives. This study also provides an evidence-based foundation to guide capability building programs, governance modernization, and future research collaborations across the Brazilian cybersecurity ecosystem.

Keywords: Cybersecurity Governance, Secure Software Development, DevSecOps, AI Security, Cyber Resilience

1. Introduction

Cybersecurity has become a foundational pillar for organizational resilience, digital transformation, and national security. As modern institutions depend increasingly on interconnected systems, cloud infrastructures, and AI-enhanced services, the attack surface expands and threatens operational continuity across both public and private sectors [13, 26]. Recent advances in

generative AI, big data analytics, and hyper-connected supply-chain ecosystems have created new forms of systemic vulnerability that require not only technological solutions but also governance centered approaches to risk management [7, 14, 33, 38], [30]. International frameworks such as the NIST Cybersecurity Framework [5] and ISO/IEC 27001 [36] emphasize the importance of continuous assessment, capability development, and proactive risk mitigation. Yet, the rapid evolution of threats, including ransomware, supply-chain compromises, adversarial machine learning, and insider misuse, continues to outpace institutional readiness [13].

In this context, recent studies emphasize that cybersecurity should be addressed as an organizational capability that integrates people, processes, and technology, rather than being treated solely as a technical concern [30]. The scientific literature echoes these concerns by demonstrating the growing complexity of cybersecurity skill demands and organizational capability gaps. Studies on workforce development highlight the persistent mismatch between required and available expertise, particularly in emerging areas such as AI security, cloud defense, and cyber-physical protection [28]. Research on cybersecurity curricula and engineering skills similarly indicates fragmentation and lack of harmonization in training programs, especially for technical roles operating in high risk environments [19, 3]. Qualitative analyses of professional development trajectories show that cybersecurity practitioners often lack structured opportunities for upskilling and rely heavily on informal learning and experiential knowledge, which limits organizational resilience [12]. Complementary findings demonstrate that cyber ranges can support realistic and scalable training, but their institutional adoption remains uneven across organizations [11, 8, 3].

Furthermore, prior empirical studies highlight that organizational awareness, training, and learning mechanisms are key determinants of cybersecurity effectiveness, reinforcing the need for continuous capability development [30]. However, these dimensions are often analyzed independently from secure development practices and governance structures.

In parallel, emerging technologies introduce new strategic challenges. A growing body of research examines how generative AI impacts vulnerability assessment, risk prediction, and adversarial attack surfaces [25]. Other studies investigate determinants of cybersecurity investments and organizational behavior, highlighting that budget allocation, governance maturity, and perceived risk strongly influence decision-making and adoption of secure-by-design practices [32, 13]. Work on cryptography, post-quantum security,

and identity management emphasizes the urgency of preparing institutions for disruptive technological shifts in authentication, encryption, and digital sovereignty [9]. Finally, recent research underscores the rise of AI governance, ethical risk, and regulatory complexity as central concerns for digital services, especially within the public sector [26, 1]. However, prior studies rarely integrate risk perception, development challenges, and emerging research priorities into a single multidimensional analysis, particularly in developing regions such as Brazil.

Additionally, empirical evidence from DevSecOps and cybersecurity governance research indicates that security practices are frequently fragmented across organizational units, with limited integration between development pipelines, governance mechanisms, and strategic decision-making [41, 2]. This fragmentation hinders the establishment of a cohesive and effective cybersecurity posture.

Despite extensive progress, several gaps remain. Existing studies tend to focus on isolated aspects of the cybersecurity ecosystem such as workforce skills, threat modeling, incident response, or AI-based risk assessment while fewer works provide a holistic understanding of how organizations jointly perceive risks, development challenges, and research priorities. Furthermore, most prior research concentrates on mature markets or highly regulated sectors, with limited attention to diverse institutional contexts such as those found in Brazil's public and private ecosystems.

Therefore, there is a lack of empirical studies that simultaneously examine organizational, technical, and governance dimensions of cybersecurity from the perspective of practitioners, particularly in emerging economies [30, 13]. This gap limits the understanding of how cybersecurity strategies are effectively perceived, prioritized, and operationalized in real-world organizational settings.

To address these gaps, this study investigates how organizations from multiple sectors perceive their cybersecurity posture across three dimensions: (i) infrastructure and governance risks, (ii) secure software development and DevSecOps practices, and (iii) strategic priorities for emerging cybersecurity technologies.

The main contribution of this work is to provide a multidimensional and practitioner-centered analysis that bridges technical, organizational, and strategic perspectives, offering empirical evidence from the Brazilian context and extending current international literature on cybersecurity readiness and DevSecOps adoption.

Through a survey of 88 practitioners working in cybersecurity, software engineering, and governance roles, we analyze organizational exposure, capability gaps, and forward-looking research interests. This multidimensional perspective enables a more integrated view of the cybersecurity landscape, considering both operational needs and long term strategic orientations.

The survey findings reveal important insights into institutional priorities. Respondents highlight structural weaknesses in governance, third-party ecosystems, and vulnerability management as dominant sources of organizational risk. Challenges in secure software development remain widespread, particularly regarding sensitive data exposure, insufficient automation, and limited DevSecOps maturity. With respect to future directions, practitioners emphasize the strategic importance of AI security, cyber resilience, cloud and hybrid-architecture protection, Governance, Risk, and Compliance (GRC) integration, and Zero Trust adoption. These results indicate strong sectoral alignment around resilience-driven and governance centric approaches to cybersecurity, underscoring the need for coordinated research, policy development, and capacity building initiatives. These findings inform policy makers, Chief Information Security Officers (CISOs), security teams, and training programs on where capability gaps are most critical and where strategic investments are likely to have the greatest impact.

2. Background and Related Work

2.1. *Cybersecurity Landscape*

Contemporary organizations operate in an environment marked by rapidly evolving cyber threats, systemic digital dependencies, and growing regulatory pressures. The acceleration of digital transformation across public and private sectors has expanded the attack surface and exposed structural weaknesses in infrastructure, governance, and supply-chain ecosystems. Studies increasingly highlight that cybersecurity risks emerge not only from technical vulnerabilities but also from organizational complexity, legacy systems, insufficient governance practices, and the interdependence between internal and external digital assets [32, 13, 30]. International standards such as the NIST Cybersecurity Framework [10] and ISO/IEC 27001 [36] emphasize the need for continuous risk assessment, resilience strategies, and coordinated security management. However, empirical evidence suggests persistent disparities in cybersecurity maturity, particularly in developing regions and highly regulated sectors [13].

Recent empirical studies further indicate that organizations exhibit heterogeneous levels of cybersecurity readiness, influenced by governance structures, resource availability, and sector-specific constraints, reinforcing the importance of context-aware analyses [30].

These foundational studies contextualize the systemic risk patterns that emerged in our survey (RQ1), particularly the interplay between governance gaps, legacy systems, and supply-chain dependencies.

2.2. Secure Software Development and DevSecOps

The integration of security into the software development lifecycle has become necessary amid increasing exploitation of software supply-chain vulnerabilities, misconfigurations, and insecure development practices. DevSecOps has emerged as an important approach to embedding security automation, continuous testing, and compliance enforcement into CI/CD pipelines. Nevertheless, research shows that organizations still struggle with limited developer training, lack of security culture, and insufficient adoption of secure coding and automated verification techniques [28] [41, 2]. Furthermore, modern development pipelines depend heavily on external components, third-party libraries, and cloud native architectures, amplifying the need for Software Bill of Materials (SBOM), Supply-chain Levels for Software Artifacts (SLSA), infrastructure-as-code hardening, and continuous monitoring.

Empirical evidence also suggests that the adoption of DevSecOps practices remains uneven, particularly in small and medium-sized enterprises, where resource constraints, limited expertise, and tooling complexity hinder the implementation of secure-by-design principles [8].

Despite the proliferation of best practices, recent empirical studies indicate that secure-by-design principles remain inconsistently implemented across sectors, often due to skill shortages, tooling fragmentation, and organizational constraints [2].

2.3. AI and Cybersecurity

Artificial Intelligence has become a dual-use technology in cybersecurity, enabling both advanced defensive capabilities and novel attack vectors. On the defensive side, AI systems support anomaly detection, threat hunting, log correlation, and automated incident response. Emerging research on cyber ranges and AI enabled training environments demonstrates the potential to enhance operational readiness and practitioner skills [11]. On the offensive side, recent work reveals how generative AI models can facilitate phishing

campaigns, malware generation, vulnerability discovery, and large-scale social engineering [25]. The rapid adoption of LLMs has also introduced risks such as prompt injection, data leakage, model poisoning, and unauthorized access to sensitive information processed by AI systems [31]. These developments highlight the growing convergence between AI governance and cybersecurity risk management, requiring integrated approaches that address technical, organizational, and regulatory dimensions simultaneously.

These developments intensify the need for robust AI governance, privacy preserving mechanisms, regulatory alignment, and comprehensive workforce training capable of handling AI augmented cyber operations.

Recent advances in generative AI and autonomous AI agents also introduce additional organizational risks, including uncontrolled decision-making, excessive reliance on AI-generated outputs, insecure integration of LLMs into operational workflows, and expanded attack surfaces associated with AI-enabled automation. These risks reinforce the need for secure AI lifecycle management, continuous human oversight, model monitoring, and governance mechanisms capable of addressing both technical and organizational vulnerabilities associated with AI adoption.

2.4. Related Work

Several studies examine dimensions closely aligned with the focus of this research, including organizational cybersecurity risks, secure development challenges, workforce readiness, and emerging technologies. First, Rattanapong et al. [32] investigated how perceived threat severity, regulatory pressure, and organizational characteristics drive cybersecurity investment decisions, offering insights relevant to our analysis of institutional risk perceptions (RQ1). Second, Parkar and Mishra[28] provided a comprehensive review of workforce development challenges, highlighting shortages in security expertise, training gaps, and the increasing need for skills in automation and secure development issues that are directly reflected in our findings for RQ2.

Third, studies on cyber ranges such as Glas et al. [11] explored training environments for threat detection, incident response, and DevSecOps, informing our analysis of organizational capability gaps. Fourth, efforts to update cybersecurity curricula [19] emphasized the importance of preparing future professionals for secure software engineering, AI enabled threats, and compliance obligations. Fifth, the qualitative study [12] reinforced that

cybersecurity maturity is strongly shaped by continuous professional development, governance alignment, and institutional culture dimensions that also emerged prominently in our survey results.

Sixth, systematic taxonomies of AI enabled vulnerabilities [25] and analyses of LLM driven attacks [31] provided a detailed understanding of adversarial AI risks, supporting our examination of emerging cybersecurity priorities (RQ3). Finally, [6] underscored the growing interdependence between cyber risk management, operational continuity, and resilience engineering, themes that are likewise reflected in respondents' prioritization of cyber resilience, cloud security, and Zero Trust.

Despite these contributions, existing studies are often limited to specific dimensions such as workforce, governance, or technical practices and rarely provide an integrated, practitioner-centered perspective that simultaneously captures organizational risks, development challenges, and strategic priorities. Moreover, most empirical evidence originates from mature markets, with limited representation of emerging economies and hybrid public-private contexts, which constrains the generalizability of existing findings.

Existing literature highlights fragmented yet convergent evidence: organizations face structural cybersecurity risks, uneven secure development practices, and increasing exposure to AI enabled threats. Our empirical survey contributes to this body of knowledge by offering a data driven characterization of institutional challenges, maturity gaps, and emerging research priorities within Brazilian public and private sectors, thereby extending prior international findings through a localized and practice oriented perspective.

These gaps directly motivate the research questions of this study, which aim to capture how practitioners perceive cybersecurity risks (RQ1), development challenges (RQ2), and future priorities (RQ3) in an integrated manner.

3. Study Settings

This section outlines the empirical context of the study examined through the survey. The instrument was designed to capture organizational perceptions and practices across three core dimensions of contemporary cybersecurity: (i) exposure to infrastructure and governance risks, (ii) challenges in secure software development and DevSecOps adoption, and (iii) strategic priorities related to emerging technologies and security domains.

Given that cybersecurity maturity varies substantially across sectors, the survey targeted professionals from public, private, academic, and critical

infrastructure organizations. The instrument collected organizational attributes (e.g., size, role structures, existence of cybersecurity units) that enable contextualized interpretation of results and support comparative analysis across different institutional profiles.

The following subsections detail the participant characteristics, survey structure, and measurement approach used in the study. Before presenting these elements, we introduce the research questions guiding our investigation.

3.1. Research Questions

The survey instrument captures perceptions of cybersecurity risks, development practices, and strategic priorities across diverse organizational contexts. Building on these dimensions, we formulated three research questions aimed at understanding how organizations assess their current challenges and anticipate future needs.

RQ1. How do organizations perceive and prioritize the main cybersecurity risks and infrastructure weaknesses?

A comprehensive understanding of perceived risks is important for identifying where organizations experience the highest exposure and which structural weaknesses they consider most vital. The survey captures a range of risk factors such as supply-chain dependencies, governance gaps, and operational vulnerabilities allowing us to assess how these elements shape organizational risk postures.

RQ2. What are the main challenges faced in secure software development and DevSecOps integration across organizations?

Secure development practices remain uneven across sectors, and many organizations struggle to embed security into their development pipelines. By examining the security challenges reported by practitioners, this question helps reveal operational obstacles, cultural barriers, and capability gaps that undermine DevSecOps adoption and secure-by-design principles.

RQ3. What emerging cybersecurity domains do organizations consider most relevant for future investment and research?

Rapid technological evolution requires organizations to anticipate future needs and allocate resources strategically. The survey includes items related to quantum security, AI governance, supply-chain defense, cyber resilience, and other emerging domains. Understanding

how organizations prioritize these areas provides insight into evolving strategic demands and helps identify opportunities for targeted research and capacity building.

3.2. Survey Design

The survey instrument was designed to capture organizational perceptions and practices across key cybersecurity domains. Following established guidelines for personal opinion surveys [18], we developed a structured questionnaire composed of closed-ended and open-ended items organized into five thematic sections. The instrument was implemented using Google Forms and formulated to ensure clarity, consistency, and relevance for professionals working in cybersecurity or ICT related roles.

The first section (*Identification*) collects contextual information about respondents and their organizations, including sector, size, existence of cybersecurity units, and role characteristics. These attributes provide necessary control variables to contextualize differences in risk perception and cybersecurity maturity. The second section (*Infrastructure, Governance, and supply-chain*) assesses how respondents perceive the relevance and impact of core infrastructure risks, supply-chain dependencies, and governance mechanisms. This section uses Likert scale ratings to prioritize organizational exposure to issues such as technological obsolescence, patch management, incident response capabilities, and external service vulnerabilities.

The third section (*Information Security and Secure Development*) captures challenges related to secure coding, DevSecOps adoption, vulnerability management, and developer oriented security practices. Respondents select the main technical and organizational obstacles encountered in their secure development processes. The fourth section (*Artificial Intelligence and Cybersecurity*) explores current uses of AI technologies in cybersecurity operations, including anomaly detection, threat intelligence, and automated response. It also includes an open-ended item allowing respondents to report specific concerns associated with AI enabled security tools.

Finally, the fifth section (*Training, Research, and Innovation*) asks participants to rate the strategic importance of emerging cybersecurity topics such as quantum security, adversarial machine learning, cloud security, Zero Trust architectures, and digital supply-chain defense and to indicate interest in research collaboration. Collectively, these sections operationalize the multidimensional construct underlying this study: organizational cybersecurity posture, development practices, and strategic technological priorities. The

instrument was internally reviewed by researchers with experience in cybersecurity and empirical methods to refine question clarity and ensure alignment with the study objectives. The final version of the survey is summarized in Table 1.

Table 1: Survey Questions and Mapping to Research Questions

ID	Question	Response Type	RQ
Section 1. Identification			
Q1	Email (used only for contact; not stored with responses).	Open text	-
Q2	Do you agree to participate in this study?	Single choice (Yes/No)	-
Q3	Type of organization.	Single choice	-
Q4	Approximate number of employees in the organization.	Single choice (size ranges)	-
Q5	How long has the cybersecurity area existed in the organization?	Single choice	RQ1
Q6	Approximate number of employees working in cybersecurity.	Single choice	RQ1
Q7	Main cybersecurity domains in which the institution operates.	Multiple choice (up to 3)	RQ1
Q8	What is your current role level?	Single choice	-
Q9	What is your highest educational level?	Single choice	-
Section 2. Infrastructure, Governance, and supply-chain			
<i>Perceived importance of risk and infrastructure factors</i>			
Q10-1	Network connectivity and performance failures.	Likert 5-point scale	RQ1
Q10-2	Dependency on suppliers and third-party services (digital supply-chain).	Likert 5-point scale	RQ1
Q10-3	Technological obsolescence (hardware/software).	Likert 5-point scale	RQ1
Q10-4	Lack of clear IT governance and security policies.	Likert 5-point scale	RQ1
Q10-5	Vulnerabilities in outsourced services, cloud platforms, and APIs.	Likert 5-point scale	RQ1
Q10-6	Insider threats and privileged misuse.	Likert 5-point scale	RQ1
Q10-7	Weaknesses in incident response capability.	Likert 5-point scale	RQ1
Q10-8	Limited vulnerability management practices.	Likert 5-point scale	RQ1
Q10-9	Failures in patching and update management.	Likert 5-point scale	RQ1
Q10-10	Software development security/quality issues affecting protection.	Likert 5-point scale	RQ1
Q11	Does your organization have formal security assessment policies?	Single choice (Yes/No)	RQ1
Q12	Please describe cybersecurity incidents or risks perceived in your digital supply-chain.	Open-ended	RQ1
Section 3. Information Security and Secure Development			
Q13	Main digital security challenges faced by the organization (select up to three).	Multiple choice (up to 3)	RQ2
Section 4. Artificial Intelligence and Cybersecurity			
Q14	How is AI used in your organization for cybersecurity? (Select all that apply)	Multiple choice (multiple selection)	RQ1
Q15	Would you like to report specific concerns about the use of AI in security?	Open-ended	RQ1
Section 5. Training, Research, and Innovation			
<i>Importance of emerging topics for applied research</i>			
Q16-1	Quantum computing applied to security.	Likert 5-point scale	RQ3
Q16-2	Post-quantum cryptography.	Likert 5-point scale	RQ3
Q16-3	Security in AI and adversarial machine learning.	Likert 5-point scale	RQ3
Q16-4	Secure software development and DevSecOps.	Likert 5-point scale	RQ3
Q16-5	Blockchain and smart-contract security.	Likert 5-point scale	RQ3
Q16-6	Cyber defense and hybrid warfare.	Likert 5-point scale	RQ3
Q16-7	IoT and embedded systems security.	Likert 5-point scale	RQ3
Q16-8	Cyber intelligence and threat hunting.	Likert 5-point scale	RQ3
Q16-9	Governance and public policy in digital security.	Likert 5-point scale	RQ3
Q16-10	Ethics and regulation in AI.	Likert 5-point scale	RQ3
Q16-11	Cloud security and hybrid architectures.	Likert 5-point scale	RQ3
Q16-12	Governance, Risk Management and Compliance (GRC).	Likert 5-point scale	RQ3
Q16-13	Offensive security (Red Team / pentesting).	Likert 5-point scale	RQ3
Q16-14	Incident response, containment, and cyber recovery.	Likert 5-point scale	RQ3
Q16-15	Digital supply-chain security.	Likert 5-point scale	RQ3
Q16-16	Zero Trust architectures.	Likert 5-point scale	RQ3
Q16-17	Cyber resilience and operational continuity.	Likert 5-point scale	RQ3
Q16-18	Differential privacy and AI/Big Data data protection.	Likert 5-point scale	RQ3

Continued on next page

Table 1 (continued)

ID	Question	Response Type	RQ
Q17	Do you want to participate in UnB research partnerships/groups on these topics?	Single choice (Yes/No/Maybe)	RQ3
Q18	Briefly describe your institutional research focus or interest.	Open-ended	RQ3

3.3. Pilot Study

Before deploying the final version of the survey, we conducted a pilot study with eight cybersecurity professionals from our professional network. The goal of this step was to assess the clarity, coherence, and practical applicability of the questionnaire, following common recommendations for survey validation in empirical software engineering [18].

Participants in the pilot reviewed all survey items and provided feedback on wording, interpretation, and response formats. Only minor adjustments were required, primarily related to improving textual clarity and simplifying the phrasing of certain questions. No structural changes, additions, or removals of items were necessary, indicating that the instrument was well aligned with the study objectives and suitable for distribution to a broader audience. The refined version of the survey, incorporating these clarity improvements, was then used in the main data collection phase.

3.4. Participants

The target population of this study comprises professionals involved in cybersecurity, secure software development and DevSecOps, Governance, Risk, and Compliance (GRC), and related technological roles. Participants were drawn from organizations in the public sector, private industry, academia, and critical infrastructure domains. This diversity allows the analysis to capture heterogeneous cybersecurity practices and risk perceptions across institutional contexts with varying regulatory obligations and maturity levels.

A total of 88 responses were collected (after removing incomplete submissions), representing participants with different organizational roles, including technical specialists, managers, and executives. The survey also captured variation in organizational characteristics such as size, sector, and the existence and maturity of dedicated cybersecurity units. These attributes serve as contextual variables to support comparative analysis across respondents and to better interpret differences in reported practices, challenges, and priorities.

3.5. Data Collection

Data were collected using an online questionnaire developed in Google Forms. The survey link was distributed through professional networks, institutional channels, mailing lists, and direct invitations to cybersecurity practitioners. Participation was voluntary and anonymous, and no personally identifiable information was stored alongside survey responses. Before the main data collection phase, we conducted a pilot with eight cybersecurity professionals to refine the clarity of the instrument. After incorporating minor textual adjustments, the final version of the questionnaire was made available for responses throughout November 2025. The survey took respondents an average of approximately 12 minutes to complete. No incentives were offered, and participants could withdraw at any time.

The recruitment strategy combined direct invitations through the authors' professional networks and targeted outreach via LinkedIn, aiming to reach practitioners with active roles in cybersecurity, secure software development, and governance.

This strategy follows a purposive and non-probabilistic sampling approach, commonly adopted in empirical software engineering studies [22]. This approach aims to reach participants with relevant professional experience in the domain, prioritizing informed and context-rich responses over random sampling.

Additionally, the sample size of this study is consistent with similar survey-based research in cybersecurity and software engineering, which often rely on comparable or even smaller numbers of participants due to the challenges of accessing qualified professionals. For example, prior empirical studies investigating cybersecurity practices, DevSecOps adoption, and organizational security behavior typically report sample sizes within similar ranges, while still providing meaningful and actionable insights [32, 28, 26].

These studies demonstrate that, in practitioner-focused cybersecurity research, the relevance and expertise of participants are often more critical than large sample sizes, particularly when the goal is to capture informed perceptions and organizational practices rather than to achieve statistical representativeness.

Although the sample size ($n=88$) may appear modest at first glance, it is aligned with common practices in empirical Software Engineering research. Previous studies highlight that obtaining large and statistically representative samples in this field is inherently challenging due to restricted access to practitioners and the lack of comprehensive population frames [23].

Furthermore, empirical evidence indicates that Software Engineering studies frequently rely on small samples. For instance, a large-scale analysis of experiments shows that 84% of studies include 40 or fewer participants, with a median of approximately 24 participants [16].

In addition, survey research guidelines emphasize that, in many cases, non-probabilistic sampling approaches (e.g., convenience or snowball sampling) are necessary due to the difficulty in defining and accessing the target population [17].

Therefore, rather than aiming for statistical generalization, this study focuses on analytical generalization by collecting data from qualified practitioners with relevant experience. In this context, the sample size adopted is not only acceptable but also exceeds the typical sample sizes reported in the literature.

All responses were exported from the platform in CSV format for subsequent analysis. The dataset includes closed-ended items primarily Likert scale ratings and categorical selections enabling quantitative descriptive and comparative analysis, as well as open-ended questions that support qualitative thematic exploration of organizational concerns and challenges.

3.6. Data Analysis

The analysis combined quantitative and qualitative procedures. Closed-ended items were analyzed using descriptive statistics, including frequency distributions, measures of central tendency, and variability, to characterize organizational perceptions of risks, secure development challenges, and emerging technology priorities. Likert-scale items were treated as ordinal data, and results were summarized using medians and interquartile ranges, complemented by visualizations such as bar charts and stacked frequency plots.

For categorical questions that allowed multiple selections, proportional analysis was conducted to account for varying response patterns across domains of expertise. These results support comparative interpretation of cybersecurity practices across diverse professional roles and organizational contexts.

Open-ended responses were analyzed using qualitative content analysis. We adopted an inductive coding approach to identify recurring concepts, concerns, and contextual factors reported by respondents. Codes were iteratively grouped into higher level categories, enabling the extraction of themes related to supply-chain risks, AI related concerns, governance challenges, and

research interests. This qualitative layer adds contextual nuance to the quantitative findings and supports triangulation across data types. The combined procedures provide a comprehensive understanding of how organizations perceive their current cybersecurity posture and anticipate future technological needs.

3.7. Ethics

The study followed established ethical guidelines for research involving human participants. No personally identifiable information (such as names, organizational affiliation, or contact details) was stored together with survey responses. Although the survey form included an optional email field for the sole purpose of enabling future contact, these data were not linked to the analytical dataset and were removed prior to analysis. Before beginning the questionnaire, participants were informed about the study's objectives, the voluntary nature of participation, the anonymity of responses, and the intended scientific use of the data. Only individuals who explicitly agreed to these terms proceeded to the survey.

4. Results

4.1. Profile

Table 2 summarizes the respondents' profile ($n=88$). As part of the identification section, some participants voluntarily provided an email address (Q1) exclusively for the purpose of receiving the final research results. These emails were not stored together with the analytical dataset. All participants who proceeded with the questionnaire explicitly agreed to take part in the study (Q2), resulting in a 100% acceptance rate. Regarding the type of organization (Q3), participants came from a heterogeneous set of sectors, with a stronger representation from government agencies (26.1%) and public companies (19.3%), followed by private companies (17.0%) and financial institutions (10.2%). Judiciary bodies, higher education institutions, research and innovation centers, and security forces each accounted for 8.0% of the sample. A small share of responses was associated with social organizations, mixed-economy corporations, and autonomous social services (each 1.1%). This distribution indicates that the survey reached professionals embedded in both public and private environments, including regulated and important domains.

With respect to organization size (Q4), most respondents work in large institutions. Organizations with 2,000 to 9,999 employees represent 34.1% of the sample, and those with 10,000 or more employees account for 29.5%. Medium-sized organizations (500 to 1,999 employees) correspond to 17.0%, while smaller organizations below 500 employees jointly represent 19.3%. This suggests that the data mainly reflects cybersecurity realities in complex and high-scale institutional settings.

The maturity of the cybersecurity area (Q5) also shows a consolidated landscape. A majority of organizations report having a cybersecurity area for more than five years (62.5%), while 15.9% indicate three to five years and 14.8% report one to three years. Only a small fraction stated that the area does not exist (3.4%) or has been created in the last year (3.4%). These results point to an overall mature baseline in terms of formal cybersecurity structures across participating organizations.

Cybersecurity team size (Q6) follows a similar pattern, although with meaningful variation. The most frequent ranges are 6 to 20 professionals (33.0%) and 0 to 5 professionals (26.1%), indicating that a substantial portion of organizations still operate with relatively small dedicated security teams. Mid-sized teams of 21 to 50 professionals appear in 19.3% of organizations, while larger teams above 50 professionals are less common (20.5% combined). This dispersion suggests different capacity levels even among mostly large and mature organizations.

The main cybersecurity domains in which institutions operate (Q7) highlight where expertise and institutional effort are concentrated. Infrastructure, networks and perimeter security is the most frequently selected domain (53.4%), followed by governance and risk management (45.5%) and incident response (40.9%). Secure software development and DevSecOps appears as a core domain for 26.1% of organizations, while cloud and virtualization security is selected by 20.5%. Offensive security (18.2%) and cyber defense strategies and policies (17.0%) also show notable presence. Other domains, such as cyber intelligence, laws and compliance, and cryptography, appear in the range of 11.4% to 14.8%, whereas supply-chain security, IoT security, and AI or ML applied to security remain niche areas in the current organizational scope. Overall, the distribution indicates stronger institutional emphasis on foundational operational security and governance, with more specialized or emerging domains still gaining traction.

Concerning professional role level (Q8), respondents are mostly distributed between technical professionals (40.9%) and managers (37.5%), with execu-

tives representing 17.0% and researchers 4.5%. This balance provides input from both operational and decision-making perspectives. Finally, the educational background (Q9) indicates a highly qualified sample, with most respondents holding a master's degree (53.4%) or a specialization diploma (33.0%). Smaller shares reported having an undergraduate degree (5.7%) or a PhD (8.0%). This profile reinforces that the findings reflect perceptions from a professionally experienced and academically trained cybersecurity community.

Table 2: Profile of survey respondents (n=88).

Category	#	%
Type of Organization		
Private company	15	17.0
Public company	17	19.3
Government agency	23	26.1
Judiciary	7	8.0
Higher education institution	7	8.0
Research and innovation center	7	8.0
Security forces	7	8.0
Financial institution	9	10.2
Social organization	1	1.1
Mixed-economy corporation	1	1.1
Autonomous social service	1	1.1
Organization Size		
Up to 20 employees	1	1.1
21–99 employees	8	9.1
100–499 employees	8	9.1
500–1,999 employees	15	17.0
2,000–9,999 employees	30	34.1
10,000 or more employees	26	29.5
Maturity of Cybersecurity Area		
Area does not exist	3	3.4
Less than 1 year	3	3.4
1–3 years	13	14.8
3–5 years	14	15.9
More than 5 years	55	62.5
Cybersecurity Team Size		
0–5 professionals	23	26.1
6–20 professionals	29	33.0
21–50 professionals	17	19.3
51–100 professionals	10	11.4
101–300 professionals	6	6.8
301–1000 professionals	2	2.3
More than 1000 professionals	1	1.1
Main Cybersecurity Domains (Q7)		
Infrastructure, networks, and perimeter security	47	53.4
Governance and risk management	40	45.5
Incident response	36	40.9
Secure development / DevSecOps	23	26.1
Cloud and virtualization security	18	20.5

Continued on next page

Table 2 (continued)

Category	#	%
Offensive security (Red Team / pentesting)	16	18.2
Cyber defense strategies and policies	15	17.0
Cyber Threat Intelligence (CTI)	14	15.9
Laws, regulations and compliance	13	14.8
Cryptography and data protection	10	11.4
IoT and embedded systems security	6	6.8
AI / ML applied to security	6	6.8
Supply-chain and vendor security	3	3.4
Education and research	2	2.3
Cybersecurity regulation	1	1.1
All above except education/research	1	1.1
Crime-fighting initiatives	1	1.1
Role Level		
Technical professional	36	40.9
Manager	33	37.5
Director / Executive	15	17.0
Researcher	4	4.5
Educational Level		
Undergraduate degree	5	5.7
Specialization (Lato Sensu)	29	33.0
Master's degree	47	53.4
PhD	7	8.0

4.2. RQ.1. Perceived Cybersecurity Risks and Infrastructure Weaknesses

Regarding network connectivity and performance failures (Q10-1), respondents attributed consistently high importance to this risk factor. As shown in Figure 1, a quarter of participants rated it as very important (25.0%), while another substantial share considered it important (19.3%). Moderate importance was also frequent (22.7%), indicating that this issue is broadly recognized as a relevant source of operational and security impact. In contrast, lower importance levels were less common, with 20.5% selecting slightly important and 12.5% not important. Overall, the distribution suggests that connectivity and network performance failures are perceived as a major concern for organizational cybersecurity posture.

Regarding the dependence on external suppliers and third-party services in the digital supply-chain (Q10-2), respondents rated this factor as highly relevant to their organizations. As shown in Figure 1, most participants placed this risk in the upper importance levels, with 28.4% rating it as important and 22.7% as very important. A substantial share also viewed it as moderately important (27.3%), indicating steady concern even among organizations with different maturity profiles. Lower importance ratings were less frequent, with 17.0% selecting slightly important and only 4.5% considering it not important. Overall, these results suggest that supply-chain

dependence is broadly recognized as an important source of cybersecurity exposure across sectors.

Regarding technological obsolescence, including outdated hardware and software (Q10-3), respondents viewed this factor as a relevant and persistent organizational challenge. As shown in Figure 1, the majority of participants rated this issue at the moderate to high end of the scale: 26.1% classified it as moderately important, 28.4% as important, and 21.6% as very important. Lower ratings were less common, with 14.8% selecting slightly important and only 9.1% considering it of no importance. These results indicate that, across institutions, legacy systems and slow modernization cycles remain a significant source of cybersecurity exposure.

For the lack of clear IT governance and security policies (Q10-4), responses revealed that many organizations continue to experience structural gaps in governance practices. As illustrated in Figure 1, one-third of respondents (33.0%) rated this factor as moderately important, followed by 22.7% who considered it slightly important and 18.2% who classified it as very important. Only 17.0% rated it as important, while 9.1% viewed it as not important. Overall, these results suggest that governance-related weaknesses are widely recognized, although not uniformly prioritized across all institutions, possibly reflecting varying stages of maturity in formalizing security policies and responsibilities.

Regarding vulnerabilities in outsourced services, cloud platforms, and APIs (Q10-5), respondents also indicated a high level of concern. As shown in Figure 1, most participants rated this factor in the upper tiers of importance, with 32.9% classifying it as important and 22.7% as very important. A relevant portion of respondents (23.9%) considered it moderately important, suggesting that, across sectors, organizations consistently recognize third-party and API-related vulnerabilities as structural sources of cybersecurity exposure. Lower ratings were less common: only 17.1% viewed this issue as slightly important and 3.4% as not important. Overall, these results reinforce the central role of supplier side weaknesses and API dependencies in shaping organizational risk posture.

With respect to insider threats (Q10-6), participants showed a clear perception that this issue represents a significant organizational risk. As shown in Figure 1, almost half of the respondents rated this factor among the highest importance levels, with 22 respondents (25.0%) selecting very important and 20 respondents (22.7%) selecting important. Moderate importance was also frequently selected (29.5%), indicating that even organizations with more ma-

ture internal controls acknowledge the persistent challenges associated with privileged misuse and human-driven risks. Lower ratings were less common, with only 17.0% classifying insider threats as slightly important and 5.7% as not important. Overall, these results highlight that insider-related vulnerabilities remain a widely recognized vector of exposure across institutions.

Regarding incident response capability (Q10-7), responses showed a consistent view that preparedness for security incidents is central to organizational resilience. Most participants placed this factor in the moderate to high importance range, with 29 respondents (33.0%) rating it as moderately important, 25 (28.3%) as important, and 18 (20.5%) as very important. Together, these categories represent more than 80% of all responses. Slightly important (14.8%) and not important (3.4%) ratings were comparatively infrequent, suggesting broad recognition that incident response effectiveness directly affects operational continuity and recovery from cyber events.

Vulnerability management (Q10-8) was also identified as a necessary area of concern. As illustrated in Figure 1, over two-thirds of respondents rated this factor as important (35.2%) or very important (28.4%), reflecting a strong perception that timely detection and remediation of vulnerabilities are foundational to cybersecurity governance. Moderate importance was selected by 22.7% of participants, while lower importance ratings (11.4%) remained comparatively small. These results reinforce that vulnerability management is widely viewed as a core operational capability necessary to mitigate organizational risk.

Similarly, update and patch management (Q10-9) was considered a relevant challenge for most organizations. A majority of respondents rated this factor as important (36.4%) or very important (17.0%), while 29.5% classified it as moderately important. Only a small portion rated it as slightly important (13.6%) or not important (3.4%). These findings suggest that delays in patching, unsupported systems, and fragmented update processes continue to play a significant role in shaping institutional exposure to cyber threats.

Finally, security issues related to software development practices (Q10-10) were also prominently highlighted. As shown in Figure 1, most participants placed software development related risks in the upper half of the scale, with 22 respondents (25.0%) rating them as important and 21 respondents (23.9%) as very important. Moderate importance was selected by 31.8% of participants, reinforcing the perception that development processes particularly in environments lacking mature secure coding or DevSecOps practices remain a structural vulnerability. Slightly important (13.6%) and not im-

portant (5.7%) ratings were less frequent, indicating broad recognition that weaknesses in development pipelines directly contribute to system level risk. Figure 1 shows the distribution of responses across five importance levels.

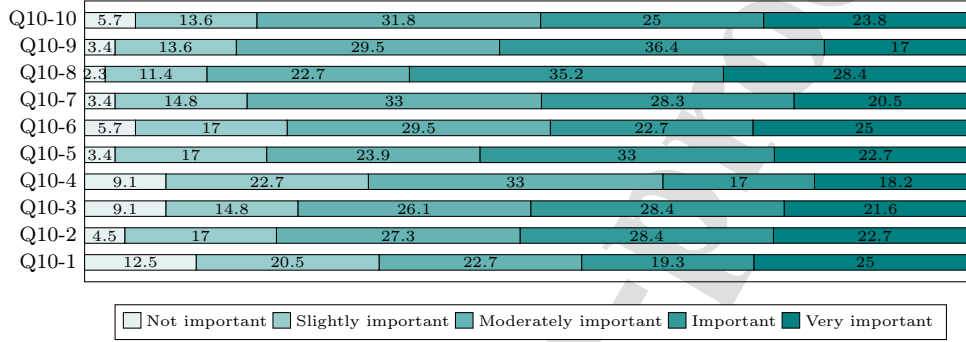


Figure 1: Perceived importance of cybersecurity risk and infrastructure factors (Q10-1 to Q10-10).

Across Q10 items, three broader patterns emerge. First, risks associated with governance, vulnerability management, and incident response consistently occupy higher importance levels, suggesting concern with institutional readiness. Second, software supply-chain dependencies and outsourced services indicate growing exposure to ecosystem-level vulnerabilities. Third, legacy systems and patching limitations reinforce that cybersecurity risks increasingly originate from accumulated organizational complexity rather than isolated technical failures.

Regarding the existence of formal security assessment policies in the organizational environment (Q11), most respondents indicated that some level of structured evaluation is in place. Specifically, 53.4% reported having formal policies with periodic reviews, suggesting established routines for assessing security controls. Another 13.6% stated that policies exist but without regular audits, indicating partial formalization that may limit enforcement and continuous improvement. In addition, 22.7% described security assessment practices as only partially implemented, reflecting transitional or uneven adoption across units. Finally, 10.2% of participants reported having no formal security assessment process. Overall, these results show that while formal security evaluation is common, a considerable share of organizations still exhibit gaps in audit regularity and full institutionalization of assessment practices.

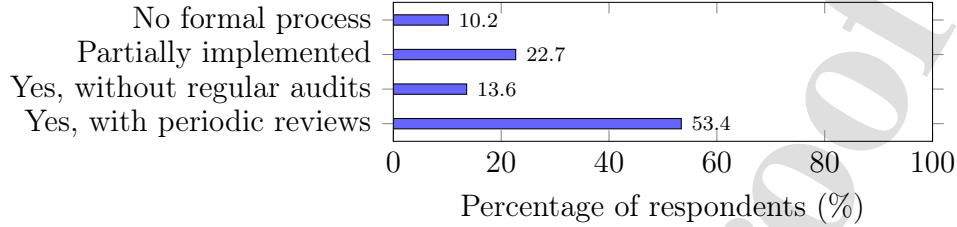


Figure 2: Existence of formal security assessment policies in respondents' organizations (Q11).

Regarding the open-ended question on incidents and risks perceived in the digital supply-chain (Q12), the responses reveal a set of recurring and structurally significant concerns across organizations. Several participants highlighted concrete cybersecurity risks associated with third-party components and software dependencies, including cooptation, abuse of legitimate access, and the possibility of service interruption, accompanied by efforts to strengthen automated Software Composition Analysis (SCA) based assessments in CI/CD pipelines. Others emphasized the absence of effective supplier governance mechanisms, noting the lack of due diligence for third parties, with assessments relying solely on self-reported questionnaires, which exposes organizations to unmanaged vulnerabilities. A related issue concerns the limited visibility into dependency chains and reused codebases, with participants reporting that users must rely on suppliers' responsibility and transparency to mitigate risks. Some respondents also described incidents involving privileged access, such as the exposure of an administrator credential later contained through rapid incident response. In addition to supply-chain and access management risks, organizations reported broader structural challenges, including insider threats, procurement constraints, failures in critical storage infrastructure, and budgetary limitations that undermine modernization and operational continuity. Collectively, these reports reinforce the perception that supply-chain security is intertwined with governance gaps, dependency visibility, privileged access management, and institutional constraints, shaping a complex risk landscape across sectors.

In addition to the quantitative assessment of risk perception, we also analyzed the open-ended responses provided in Q12, which asked participants to describe incidents or vulnerabilities perceived in their digital supply-chain. Although optional, these narratives offer valuable contextual depth by reveal-

ing concrete examples of weaknesses that are not fully captured by structured Likert-scale items. Using an inductive coding approach, we identified six recurring themes reflecting organizational challenges related to supplier oversight, insider risks, software dependency, budgetary constraints, operational threats, and legacy system fragility. Table 3 summarizes these themes, the underlying sub-codes, and representative excerpts that illustrate the types of supply-chain risks encountered by the respondents.

Theme	Sub-themes / Codes	Representative Quotes
Supplier Governance and Transparency Failures	Lack of Due Diligence; Superficial vendor assessment; Low visibility of dependencies; Opaque communication from suppliers	“Absence of effective third-party Due Diligence, evaluations rely only on self-filled questionnaires.”
		“Low visibility of existing dependencies and associated vulnerabilities; users depend on suppliers being transparent and proactive.”
Insider and Access Management Risks	Abuse of legitimate access; Insider threats; Credential exposure; Privilege misuse	“A privileged service credential was exposed by support staff; fortunately no unauthorized access was recorded.”
		“Co-optation and abuse of legitimate access, with potential service interruption.”
Software supply-chain Vulnerabilities	Reuse of vulnerable components; Limited SCA/SBOM practices; Software dependency risks	“We rely heavily on external components; SCA scans guide prioritization of updates to high-risk third-party libraries.”
Organizational and Budgetary Constraints	Procurement restrictions; Budget limitations; Lack of investment in cybersecurity; Limited enforcement of policies	“Budget and procurement restrictions prevent acquisition of essential security equipment.”
		“There is a lack of specific investments in cybersecurity and difficulty enforcing policies.”
Critical Operational Risks	Operational continuity concerns; Infrastructure failures; High-impact operational threat scenarios	“There is constant concern about an air-traffic blackout caused by a hacker compromising control systems.”
		“Catastrophic storage failure in another unit impacted operations.”
Legacy and Maintainability Issues	Legacy systems fragility; Maintainability problems; Security weaknesses in old systems	“Difficulty maintaining legacy systems and failures in client security.”

Table 3: Qualitative coding of open-ended responses for supply-chain risks (Q12).

Regarding the use of Artificial Intelligence for cybersecurity activities (Q14), Figure 3 shows that AI adoption is uneven across organizations and primarily concentrated in operational monitoring tasks. The most frequently

reported AI use is monitoring and anomaly detection (38.6%), followed by log analysis and event correlation (31.8%) and fraud prevention (29.5%). These results indicate that organizations tend to prioritize AI for continuous surveillance and data intensive detection routines.

Strategic uses appear less widespread, although a relevant share of respondents reported applying AI to risk analysis and attack prediction (20.5%) and endpoint security (18.2%). Automation of incident response is still emerging, reported by 17.0% of participants. More specialized applications, such as detecting anomalous internal user behavior and advanced threats, were selected by 14.8% each, while vulnerability classification and prioritization (10.2%) and forensic investigation support (11.4%) remain secondary uses. On the other hand, over one third of the respondents (34.1%) indicated that their organizations currently do not use AI for cybersecurity purposes, suggesting persistent barriers to adoption or a lack of maturity in AI enabled security operations. Overall, the distribution highlights a scenario where AI is mostly leveraged for detection and monitoring, with fewer organizations advancing toward predictive, automated, or adversarially robust security capabilities.

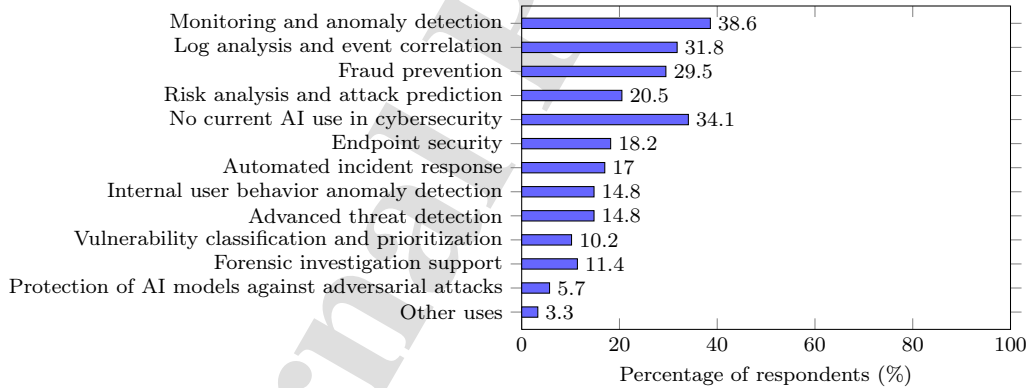


Figure 3: Use of Artificial Intelligence for cybersecurity in respondents' organizations (Q14).

In addition to the structured items on AI usage, the open-ended responses on AI related security concerns (Q15) reveal a set of nuanced challenges that extend beyond technical implementation. As summarized in Table 4, participants frequently reported governance and policy gaps, including the absence of formal rules for secure AI use and the emergence of shadow AI operating outside institutional oversight. Data protection risks were also prominent,

particularly worries about the exposure of sensitive information in prompts, potential model training by external providers, and cross border data transfers. Several respondents highlighted threats specific to AI and LLMs such as prompt injection, jailbreak attacks, data poisoning, and privacy attacks indicating growing awareness of adversarial risks. Organizational maturity issues also emerged, including limited staff training, insufficient human oversight, and lack of institutional readiness for secure AI adoption. Finally, some participants emphasized supply-chain and vendor dependence risks, as well as concerns regarding model traceability, explainability, and auditability. Collectively, these narratives suggest that organizations view AI not only as an operational enabler but also as a multidimensional source of cybersecurity risk requiring stronger governance, technical safeguards, and institutional capacity building.

Taken together, the results indicate that organizations perceive cybersecurity risks as strongly interconnected rather than isolated operational problems. Risks associated with governance gaps, supply-chain dependencies, legacy systems, and vulnerability management frequently overlap, suggesting that cybersecurity exposure emerges from systemic organizational conditions instead of single technical failures. This broader pattern reinforces the importance of integrated governance, continuous monitoring, and resilience-oriented security strategies.

RQ1 Summary

Practitioners perceive cybersecurity risks as rooted in structural weaknesses spanning infrastructure, governance, and supply-chain dependencies. Key concerns include outdated technologies, reliance on external services, insider threats, and gaps in vulnerability and patch management. Despite the presence of formal assessment policies, governance inconsistencies and limited visibility into software dependencies and vendor practices persist. AI-related risks also emerge, with uneven adoption and concerns about privacy and adversarial manipulation. Overall, organizations prioritize risks stemming from complex interdependencies and governance limitations, reinforcing the need for stronger oversight and resilient security foundations.

Theme	Sub-codes	Representative Quotes (Q15)
Governance and Policy Gaps	Lack of governance; absence of formal rules; unclear or fragmented policies; shadow AI outside institutional control	“There are still no formal rules for the secure use of AI in the organization.” “We face major difficulties establishing AI governance while business areas push for urgent adoption.”
Data Security and Privacy Risks	Sensitive data exposure; leakage through prompts or uploads; insecure data handling; cross-border data transfers; confidentiality risks	“I am concerned about the exposure of sensitive data in prompts and uploads, and the possibility that providers may use them for model training without clear legal basis.” “Risk of leakage of strategic and sensitive information.”
Model Security Threats	Prompt injection; jailbreak attacks; adversarial examples; data poisoning; model drift; privacy attacks (membership inference, model inversion); misuse of embedded secrets	“Prompt injection and jailbreak attacks could lead AI agents to perform unintended or harmful actions.” “There is a real risk of data poisoning and adversarial attacks on developing models.”
Organizational Maturity and Skills Gaps	Lack of training; limited institutional readiness; insufficient oversight; lack of human-in-the-loop monitoring	“Teams still need more training, and institutional maturity for secure AI adoption is low.” “Automated decisions must remain under human supervision to ensure compliance with organizational policies.”
Vendor Dependence and Supply-Chain Risks	Dependence on external AI providers; unclear provider security practices; risk of un-governed third-party integrations	“Dependence on external AI vendors impacts continuity and availability if the service fails.” “The absence of an internally hosted corporate AI model limits data protection and increases supply-chain risks.”
Traceability, Explainability, and Auditability Issues	Low transparency; lack of auditability; insufficient monitoring; difficulty tracking model behavior	“Low traceability and explainability of AI models raise concern, as well as the handling of secrets like embedded API tokens.”

Table 4: Qualitative coding of open-ended responses regarding AI-related security concerns (Q15).

4.3. RQ2. Challenges in Secure Software Development and DevSecOps Integration

Figure 4 summarizes the main security challenges reported by practitioners regarding secure software development and DevSecOps practices (Q13). The most prominent concern is the exposure of sensitive data (47.7%), which reflects persistent weaknesses in data handling, access control, and secure storage practices across development environments. Closely related, the lack of training and security culture among developers (40.9%) emerges as an important barrier, suggesting that many institutions still struggle to embed security awareness and secure coding principles into their development work-

flows.

Technical weaknesses also play a central role. Vulnerabilities in source code and external libraries (28.4%) and insecure configurations across development, testing, and production environments (23.9%) were frequently selected, highlighting gaps in code quality, dependency management, and configuration hardening. Compliance-related issues were also relevant: 22.7% of respondents indicated the absence of integrated security requirements based on standards such as Brazilian General Data Protection Law (LGPD) [20], ISO/IEC 27001 [36], OWASP [27], or NIST [10].

Several challenges relate more directly to DevSecOps maturity. Respondents reported insufficient security testing (18.2%), limited automation of verification tools such as Static Application Security Testing (SAST), Dynamic Application Security Testing (DAST), Software Composition Analysis (SCA), and Infrastructure as Code (IaC) scanning (14.8%), and inadequate management of secrets and credentials (15.9%). Lower-frequency responses also point to fragmentation of CI/CD security pipelines, including lack of continuous security monitoring (9.1%), insufficient code-review policies (9.1%), and weak traceability or secure versioning processes (2.3%).

Overall, the results indicate that organizations face a combination of cultural, procedural, and technical barriers that hinder the consistent integration of security into development lifecycles. Rather than originating exclusively from DevSecOps processes, these challenges are rooted in more fundamental issues, particularly sensitive data exposure, insufficient security culture and training, and persistent weaknesses in source code and configuration practices which in turn constrain DevSecOps maturity. These findings reinforce the need for improved automation, developer training, secure dependency management, and compliance-driven development practices.

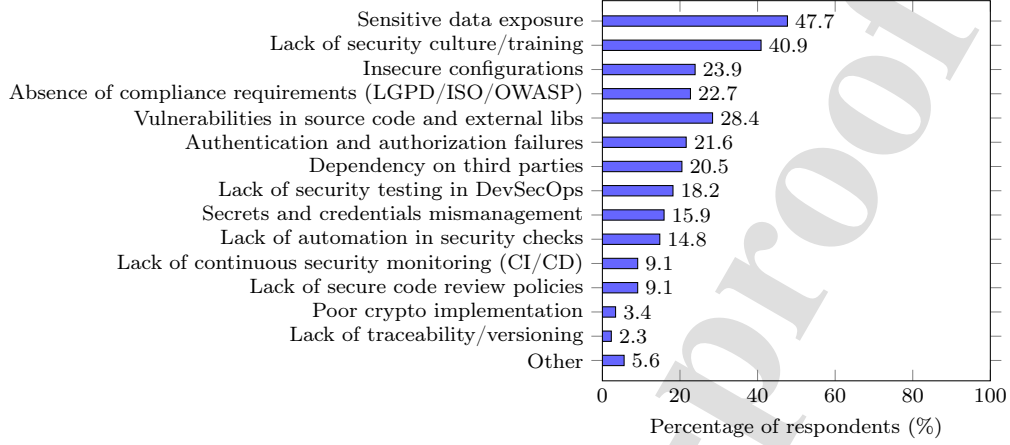


Figure 4: Main digital security challenges faced by organizations (Q13).

RQ2 Summary

Organizations face a multifaceted set of challenges in secure software development, driven by sensitive data exposure, insufficient developer training, and persistent vulnerabilities in code, dependencies, and configurations. DevSecOps adoption remains uneven, with gaps in automated security testing, secret management, continuous monitoring, and compliance integration, which appear as secondary challenges when compared to more pervasive issues such as data exposure, developer training deficits, and insecure configurations.

4.4. RQ3. Priorities for Emerging Cybersecurity Research and Innovation

Figure 5 summarizes how respondents evaluated the strategic importance of emerging cybersecurity domains (Q16-1 to Q16-18). The results reveal a strong orientation toward topics that support operational resilience, secure-by-design practices, and the governance of advanced technologies such as AI and cloud platforms. The highest rated topics include adversarial machine learning and AI security (Q16-3), with 40.9% of respondents selecting it as very important and an additional 26.1% rating it as important. Cyber resilience and operational continuity (Q16-17) also ranks prominently, with more than 70% of participants placing it within the two highest importance levels. Similar emphasis appears in cloud and hybrid architecture security (Q16-11), governance and compliance (Q16-12), and incident response and

cyber recovery (Q16-14), each showing strong concentration in the upper tiers of perceived importance.

Secure development and DevSecOps (Q16-4) continues this pattern: nearly two thirds of respondents classified it as important or very important, reinforcing concerns already reflected in RQ2 (Section 4.3). Additionally, digital supply-chain security (Q16-15) and Zero Trust architectures (Q16-16) were considered relevant by majorities of respondents, highlighting increasing attention to identity centric and dependency aware defense strategies. Other domains showed more distributed perceptions. Blockchain and smart contract security (Q16-5) and IoT security (Q16-7) received balanced ratings across moderate and high importance, suggesting heterogeneous adoption and maturity across sectors. Quantum related topics (Q16-1 and Q16-2) received the highest proportions of “not important,” yet still retained substantial interest, with many respondents acknowledging their growing strategic relevance.

Finally, emerging concerns around AI governance, ethics, and regulation (Q16-10) were strongly represented, with more than 60% rating them as important or very important. This aligns with qualitative findings from Q15, in which participants highlighted risks associated with privacy, adversarial manipulation, and lack of institutional oversight. Taken together, these results indicate that organizations prioritize emerging cybersecurity topics that are directly linked to resilience, governance, and the secure integration of advanced technologies. Areas such as AI security, cloud defense, DevSecOps, and cyber resilience stand out as central pillars for future investment and applied research.

The responses to Q17 indicate a strong interest among practitioners in engaging with future research initiatives. A majority of participants (65.9%) expressed willingness to participate in UnB research groups or partnerships focused on emerging cybersecurity topics. An additional 22.7% responded “maybe,” suggesting a substantial portion of respondents remain open to collaboration depending on project scope, alignment, or institutional support. Only a small minority (11.4%) stated they are not interested in participating. Overall, the results demonstrate a highly favorable environment for establishing applied research networks and practitioner academia collaboration, reinforcing the relevance and demand for continued investigation across the themes identified in Q16.

The open-ended responses on institutional research interests (Q18) reveal a concentrated focus on advanced cybersecurity domains that mirror

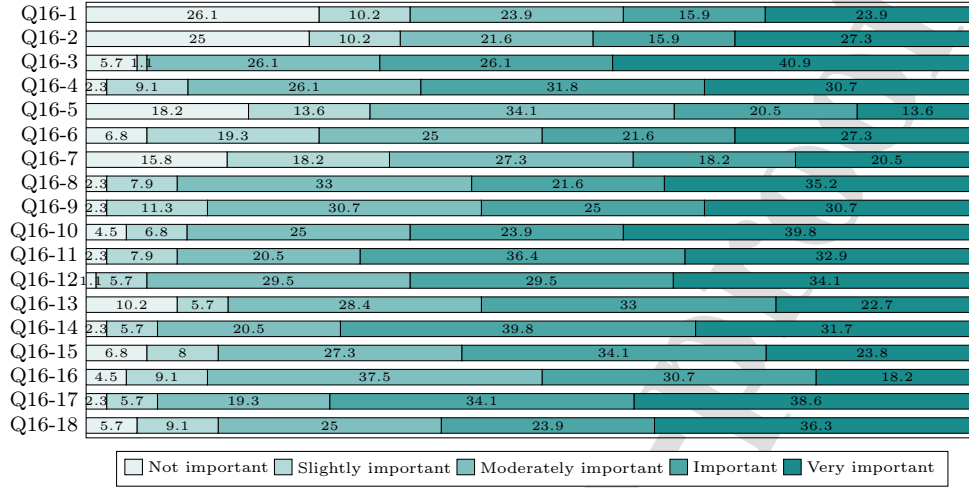


Figure 5: Perceived importance of emerging cybersecurity topics for applied research (Q16-1 to Q16-18).

the strategic priorities identified throughout the survey. As summarized in Table 5, practitioners express strong interest in AI security and adversarial machine learning, particularly concerning governance, privacy, and the secure lifecycle of LLMs. Governance, GRC, and public sector cybersecurity policy emerge as prominent themes, alongside operational domains such as threat hunting, incident response, and cyber defense. Respondents also highlight the growing relevance of secure software development and DevSecOps, digital supply-chain risk management, and the protection of critical infrastructures and operational technology. Additional priorities include post-quantum cryptography, cyber risk modelling, privacy engineering, identity management, and secure communication. Collectively, these themes indicate that institutions are orienting their research agendas toward resilience, secure-by-design engineering, and the trustworthy adoption of emerging technologies, reinforcing the forward-looking nature of the cybersecurity challenges identified in this study.

Theme	Sub-codes	Representative Quotes (Q18)
AI Security and Adversarial Machine Learning	AI governance; adversarial ML; prompt injection; jailbreak; data poisoning; AI privacy; secure LLM lifecycle; trustworthy AI	"Focus on privacy and security in the use of AI/LLMs in software development, especially attacks such as prompt injection, jailbreaks, membership inference, and data poisoning." "AI security and adversarial ML; preparation for post-quantum cryptography and operational resilience."
Cybersecurity Governance, GRC, and Public Policy	Security governance; digital public services; compliance; regulatory alignment; risk governance frameworks; ISO-based governance	"Governance and public policies in digital security; Response, Containment, and Recovery of Cyber Incidents." "Institutional interest lies in developing governance and resilience frameworks aligned with ISO 31000 and ISO/IEC 27005."
Cyber Defense, Threat Hunting, and Offensive Security	Threat hunting; cyber threat intelligence; offensive security; Red Team; phishing and ransomware defense; MSSP practices	"Research interest in Threat Hunting, since the concept is not currently applied correctly in the market." "Supply-chain security, threat hunting, and offensive security."
Secure Software Development and DevSecOps	DevSecOps maturity; SBOM; SLSA; secure CI/CD pipelines; secure coding; modernization of legacy systems	"Secure development and DevSecOps, due to applications that require technological modernization." "Complementary priorities include DevSecOps with SBOM and SLSA."
Critical Infrastructure and OT Security	Infrastructure protection; OT security; aviation cybersecurity; continuity of operations; resilience modelling	"Analysis of impacts caused by cyber risks in the financial system and critical infrastructures." "Research focused on cyber risk management in aviation, with AI-based predictive models for detection and response."
Digital Supply-Chain Security and Third-Party Risk Management	Third-party governance; dependency risks; TPRM; vendor security; ecosystem exposure	"Researching supply-chain risks (Third-Party Risk Management) in the private sector." "Strengthening the management of digital supply-chain risks and improving crisis response mechanisms."
Quantum and Post-Quantum Security	Post-quantum cryptography; quantum-resistant credentials; verifiable credentials; digital sovereignty	"Post-quantum cryptography and self-sovereign credentials." "Post-quantum cryptography, verifiable credentials, and AI for biometric fraud reduction."
Incident Response and Digital Forensics	SOAR; automated containment; forensic analysis; crisis response; RTO/RPO	"Incident response and digital forensics." "Improving mechanisms for cyber crisis response and recovery to increase resilience."
Cyber Risk Management and Organizational Resilience	Risk modelling; military risk frameworks; multicriteria prioritization; predictive risk analytics; maturity indicators	"Applied research in cyber risk management in military environments with sensitive data." "Maturity indicators for risk management and prioritization under resource constraints."
Data Protection, Privacy Engineering, and Compliance	LGPD/GDPR compliance; privacy-preserving AI; secure data lifecycle; privacy engineering	"Practical application of GRC to cybersecurity initiatives." "Differential privacy applied to large datasets and LGPD compliance."
Secure Communication and Identity Management	Identity security; verifiable credentials; secure communications; biometric fraud prevention	"Secure communication; identity management." "Verifiable credentials and AI to combat biometric fraud."
Cybercrime, Regulation, and Cyber Geopolitics	Cybercrime modelling; supranational cyber policy; geopolitical cybersecurity governance	"Research investigating whether a supranational cybercrime policy is necessary or feasible."

Table 5: Qualitative coding of open-ended responses regarding institutional research interests (Q18).

RQ3 Summary

Organizations prioritize emerging cybersecurity domains that reinforce resilience, governance, and secure-by-design practices. AI security and adversarial machine learning emerge as the leading priorities, followed by cloud and hybrid architecture protection, cyber resilience, and GRC focused governance. DevSecOps and supply-chain security remain essential concerns, alongside growing interest in Zero Trust. Overall, results reflect a forward-looking strategic agenda centered on resilient infrastructures and trustworthy AI adoption.

5. Discussion

5.1. *Structural Cybersecurity Risks and Governance Gaps*

The results of RQ1 reveal that the surveyed Brazilian organizations face deeply structural cybersecurity risks, particularly related to network instability, technological obsolescence, software supply-chain dependencies, and weaknesses in patch and vulnerability management.

These findings align with evidence from the global literature showing that modern cyber risk increasingly emerges from complex sociotechnical interdependencies [25]. The high prevalence of insider threats and configuration related weaknesses found in the survey reiterates the persistent importance of organizational factors, such as culture, processes, and governance, over purely technical controls. In addition, empirical studies conducted in different national contexts report similar patterns regarding the centrality of governance gaps, supply-chain dependencies, and legacy systems as key drivers of cybersecurity risk [13, 30]. These studies reinforce that such risks are not restricted to specific regions but represent structural characteristics of contemporary digital ecosystems.

A key insight from the responses is the existence of governance inconsistencies, including irregular audits, limited security visibility, and unclear allocation of responsibilities. The study by [14] helps explain this phenomenon through its sociotechnical transition perspective: organizations operate under different opportunity structures shaped by their perceived agency, external regulatory pressure, and presence (or absence) of institutional support. Our findings suggest that many institutions in the Brazilian public sector remain positioned between reactive compliance and operational pragmatism, lacking the structural enablers to internalize cybersecurity as a strategic asset. Regulatory fragmentation also emerged as a serious barrier, particularly regarding LGPD, NIST, ISO/IEC 27001, and sector specific regulations. This challenge is strongly corroborated by the systematic analysis in [21], which demonstrates that organizations worldwide struggle with overlapping, ambiguous, and rapidly evolving cybersecurity requirements. In particular, the authors highlight that concepts such as security-by-design and risk based approaches are normatively promoted but rarely operationalized with actionable criteria, a gap that our respondents echoed through references to unclear responsibilities, limited traceability, and inconsistent risk assessment routines.

Moreover, while our findings are largely consistent with international studies, some contextual differences emerge, particularly regarding the influence of regulatory fragmentation and institutional constraints in public-sector environments. These aspects appear more pronounced in the Brazilian context, suggesting that governance-related challenges may be amplified in settings with complex regulatory landscapes and heterogeneous organizational maturity levels.

5.2. Challenges in Secure Development and DevSecOps Integration

RQ2 identifies a constellation of obstacles affecting secure software development and DevSecOps adoption, with the most prominent being: exposure of sensitive data, insufficient developer training, vulnerabilities in external libraries, insecure configurations, and limited automation in security testing (SAST, DAST, SCA, IaC scanning). These findings mirror international studies showing that DevSecOps maturity is often hindered by gaps in skills, culture, and tooling [28]. Further evidence from recent DevSecOps research indicates that the integration of security into development pipelines remains fragmented across organizations, particularly due to the lack of alignment between development, operations, and governance functions [41, 2, 34]. This reinforces our findings by showing that the challenges identified in the Brazilian context are consistent with broader international limitations in DevSecOps maturity.

The high rates of challenges related to secure coding, secret management, and CI/CD monitoring reinforce the evidence from [11], which argues that traditional training models are insufficient for modern pipelines and must be complemented by hands-on, adversarial simulation environments. Our qualitative findings (Q12) also highlight systemic barriers such as limited supplier due diligence, constrained budgets, and insufficient visibility into software dependencies issues that directly mirror recent analyses of software supply-chain vulnerabilities and the need for SBOM oriented governance [26].

Furthermore, the strong demand for training and culture change aligns with the qualitative study of Irish cybersecurity professionals [12], which shows that secure development practices only succeed when supported by continuous professional development, institutional incentives, and clear career pathways. Our results reinforce that training cannot be incidental: it must be an ongoing component of organizational strategy.

These findings are also consistent with survey-based studies conducted in other countries, which report similar challenges in secure development prac-

tices, governance fragmentation, and workforce capability gaps, reinforcing the external validity of our results [28, 30, 26]. This convergence between our findings and prior empirical evidence strengthens the validity of our results, indicating that the observed DevSecOps challenges are not isolated phenomena but reflect broader structural limitations across different organizational and national contexts.

5.3. Future Priorities in Cybersecurity Research and Innovation

The prominence of adversarial machine learning, AI security, cloud and hybrid architecture protection, cyber resilience, and DevSecOps demonstrates that organizations are actively shifting toward future oriented cybersecurity agendas. This aligns closely with global studies indicating that AI driven threats, large scale automation, and expanded attack surfaces are reshaping cybersecurity priorities [33]. Particularly, respondents ranked adversarial ML and AI governance among the most serious topics, a finding strongly reinforced by [25], which argues that Generative AI (GenAI) requires entirely new layers of vulnerability assessment, ethical auditing, and risk management. Similarly, the emphasis on cloud security, incident response, and operational continuity is consistent with the NIST Cybersecurity Framework (CSF) evolution [5], in which resilience oriented capabilities (detect, respond, recover) become as important as protection controls. Our findings further demonstrate that interest in post-quantum cryptography, Zero Trust architectures, and supply-chain defense is increasing but remains uneven across sectors suggesting asymmetric maturity and readiness levels. Moreover, recent studies emphasize that organizations are increasingly prioritizing AI security, cyber resilience, and cloud protection as strategic domains, driven by the expansion of attack surfaces and the growing complexity of digital infrastructures [30, 26]. This convergence suggests that cybersecurity priorities are becoming globally aligned, even across different institutional and regulatory environments.

The open-ended responses (Q18) provide a broader strategic view, revealing institutional priorities ranging from AI ethics and privacy engineering to GRC modernization, threat hunting, OT security, digital forensics, and third-party risk management. These themes strongly align with comprehensive reviews on cybersecurity workforce requirements [19], which emphasize the growing need for interdisciplinary competencies bridging engineering, governance, and applied research.

5.4. *Implications for Governance, Competencies, and Practice*

The results demonstrate that cybersecurity in the Brazilian public sector is at a pivotal point. Organizations recognize the importance of strategic cybersecurity capabilities, including AI security, cloud resilience, and DevSecOps practices, but lack the structural competencies, processes, and governance maturity needed to fully implement them. The literature consistently supports this interpretation:

- studies on regulatory complexity show that compliance alone does not produce security [21];
- research on workforce development demonstrates that skills gaps are persistent and require continuous investment [29];
- analyses of generative AI threats reveal that new competencies ethical auditing, adversarial testing, model governance are urgently needed [33];
- sociotechnical studies highlight that cybersecurity capacity is shaped by organizational culture, perceived agency, and institutional support [14].

These converging findings across multiple international studies provide additional support for the validity of our results, indicating that the patterns observed in Brazilian organizations are consistent with broader global trends in cybersecurity governance, workforce challenges, and emerging technological risks.

Taken together, these insights reinforce the central contribution of this work: providing an integrated and practitioner-centered understanding of cybersecurity risks, secure development challenges, and emerging strategic priorities. Our results show that the absence of clear roles, skill sets, and proficiency levels is one of the main factors limiting the adoption of secure-by-design principles and the effective alignment between regulation and practice. The findings provide actionable guidance for institutions seeking to strengthen cybersecurity governance, prioritize capability-building initiatives, and improve organizational readiness for emerging technological risks.

An important implication of these findings concerns the potential differences between large organizations and small and medium-sized enterprises

(SMEs). While our sample includes diverse sectors, it is more representative of organizations with established cybersecurity structures, dedicated teams, and more mature governance arrangements. SMEs often operate under tighter budget constraints, limited access to specialized professionals, and less formalized security processes, which may lead to different perceptions of risk, different DevSecOps adoption patterns, and different strategic priorities. Therefore, the findings of this study should be interpreted with caution when extended to smaller organizational contexts, and future research should investigate cybersecurity practices, governance mechanisms, and capability gaps specifically in SMEs and other resource-constrained environments.

At the same time, the findings presented in this study should be interpreted as practitioner-centered perceptions rather than objective measurements of cybersecurity performance. This limitation is consistent with recent studies on privacy risks and governance in Generative AI, which emphasize that many current investigations rely predominantly on perception-based evidence, qualitative synthesis, or controlled experimental settings rather than large-scale operational validation using incident repositories or real-world cybersecurity metrics [39, 4, 24, 15, 37]. Although the reported risks and challenges are strongly aligned with prior studies, future investigations could strengthen empirical validation by combining survey perceptions with operational indicators, vulnerability databases, incident repositories, and longitudinal organizational evidence.

In summary, the literature confirms and deepens the empirical insights of RQ1–RQ3: cybersecurity risks are systemic; regulatory environments are increasingly complex; workforce capabilities remain insufficient; and emerging technologies, particularly AI, introduce new forms of uncertainty and require updated competencies [13, 30, 26, 28]. The convergence between the survey findings and prior research suggests the importance of institutionalizing governance structures, investing in continuous training, and adopting integrated competency based approaches to improve cybersecurity readiness across the public sector.

6. Threats to Validity

Following the guidelines of Wohlin et al. [40], this section discusses the main threats to validity of our findings and the strategies adopted to mitigate them. The four classical dimensions of empirical research validity are addressed: construct, internal, external, and conclusion validity. **Construct**

validity concerns whether the survey instrument accurately captured the concepts it intended to measure, such as perceived risks, secure development challenges, and strategic cybersecurity priorities. A first potential threat involves the interpretation of Likert scale items. Participants from different sectors and roles may assign different meanings to terms such as “risk severity”, “importance”, or “DevSecOps maturity”. To mitigate this, all questionnaire items were phrased using operational and concrete definitions (e.g., patching and update management, vulnerabilities in cloud platforms and APIs), reducing ambiguity and avoiding abstract constructs.

Another threat relates to the breadth of cybersecurity domains. Given the complexity of the field, the survey might not fully capture the nuances of all organizational environments. To address this, the instrument was developed based on consolidated references (NIST CSF, ISO/IEC 27001, OWASP, supply-chain security literature), and refined through a pilot with eight cybersecurity professionals who provided feedback on clarity and relevance. No structural changes were required after the pilot, indicating good alignment between constructs and measures. Finally, self-reported data may lead to social desirability bias, especially in questions concerning governance maturity or compliance. To mitigate this, participation was anonymous, no identifiers were collected, and the instrument emphasized that responses would be used only for scientific research.

Internal validity concerns whether observed patterns may be influenced by confounding factors not accounted for in the study design. Because the study is observational and cross-sectional, it cannot infer causality between variables such as organizational maturity and perceived risks. This limitation is intrinsic to survey based research. To mitigate confounding effects, the questionnaire included contextual questions about sector, organizational size, existence and age of cybersecurity units, and team size, enabling interpretation of results in the light of organizational characteristics. Another threat involves the potential influence of respondents’ professional roles. For example, executives may have broader strategic perceptions, while technical practitioners may emphasize operational challenges. The inclusion of role level categories (technical, management, executive) allows readers to interpret results with this stratification in mind. Additionally, the absence of enforced completeness could lead to partially omitted perspectives. This was mitigated by removing incomplete responses (n=88 final dataset), ensuring that all analyses are based on fully answered surveys.

External validity concerns the generalizability of findings to other con-

texts. A primary limitation is the use of a non-probabilistic, convenience-based sampling strategy. Participants were recruited through professional networks, institutional channels, and targeted outreach via LinkedIn. This recruitment approach follows a purposive sampling strategy aimed at reaching practitioners with relevant expertise in cybersecurity, software development, and governance, but it may introduce selection bias toward professionals who are more active in professional communities or have stronger engagement with cybersecurity practices.

Another important limitation is the potential overrepresentation of medium and large organizations, which typically have more structured cybersecurity capabilities and dedicated teams. As a result, the findings may not fully reflect the realities of small and medium-sized enterprises (SMEs), which often face different constraints such as limited resources, lower cybersecurity maturity, and less formalized governance structures. This limitation is particularly relevant for SMEs, whose cybersecurity practices, resource constraints, and governance maturity may differ significantly from the organizations represented in this sample.

The sample size ($n=88$) is consistent with empirical practices in cybersecurity and software engineering research, particularly in studies involving practitioner populations, where access to participants is inherently constrained. The distribution, however, includes diverse sectors (government, private industry, judiciary, financial institutions, research centers), large organizations, and professionals from different roles, which increases the heterogeneity and representativeness of perceptions.

Furthermore, rather than aiming for statistical generalization, this study adopts an analytical generalization perspective, in which findings are interpreted as insights derived from experienced practitioners and contextualized organizational environments. This approach is consistent with empirical software engineering research, where access to representative samples is limited and practitioner expertise is prioritized [23, 17, 18, 16].

Finally, while the study is situated in the Brazilian context, many of the risks, challenges, and priorities identified (e.g., AI security, supply-chain risks, DevSecOps maturity) are consistent with international findings, suggesting that the conclusions may generalize to similar institutional environments [35, 32, 28].

This limitation is consistent with challenges reported in similar empirical studies, where access to participants from smaller organizations is often restricted. As a result, the findings may reflect a bias toward more mature

cybersecurity environments, which should be considered when interpreting the results.

Conclusion validity concerns whether the empirical evidence supports the conclusions drawn, and whether analyses were appropriate for the data. The survey primarily uses descriptive statistics, which are appropriate for mapping perceptions, risk patterns, and organizational priorities but do not enable inferential causal claims. To avoid overstating findings, results are interpreted as perceptions rather than objective measurements. Another threat lies in potential variability in how respondents rate “importance” on Likert scales. This is mitigated by presenting full distributions rather than relying solely on means, and by triangulating quantitative results with qualitative coding of open-ended responses (Q12, Q15, Q18). The qualitative analysis follows an inductive content analysis procedure, with iterative coding and thematic grouping. While qualitative coding is inherently interpretative, themes were derived systematically and supported by multiple respondents’ statements, enhancing reliability. Finally, the survey design did not include statistical significance testing or correlation analysis, which could further validate relationships between variables. Given the exploratory objective of this study mapping risks, challenges, and research interest descriptive methods are sufficient and aligned with best practices for perception based surveys.

Another limitation is the absence of objective cybersecurity performance indicators or incident databases to externally validate the reported perceptions. Future studies could combine survey-based evidence with operational security metrics, vulnerability databases, or incident repositories to strengthen empirical triangulation and validation.

7. Conclusion

This study provides a comprehensive and empirically grounded view of how Brazilian organizations perceive and manage cybersecurity risks, secure software development challenges, and emerging technological priorities. The findings reveal that structural weaknesses such as supply-chain dependencies, legacy systems, governance inconsistencies, insider threats, and insufficient vulnerability and patch management remain central concerns across sectors. These results confirm that cybersecurity exposure increasingly emerges from sociotechnical interdependencies rather than isolated technical flaws. They also reinforce observations from recent literature that highlight persistent

gaps in risk governance, regulatory alignment, and the internalization of resilience-based practices within organizational structures.

Challenges in secure software development and DevSecOps integration constitute a second major contribution of this research. Practitioners report difficulties in embedding security into development pipelines, underscoring limitations in developer training, automation, secret management, code review practices, compliance integration, and supply-chain visibility. This pattern reflects longstanding concerns in the software engineering community regarding the fragile state of secure-by-design practices and the limited institutional readiness for continuous, automated, and developer-centric security processes. They illustrate that cultural, procedural, and capability related barriers remain pervasive obstacles to DevSecOps maturity.

A third contribution lies in mapping institutional priorities for future cybersecurity research and innovation. Organizations are strongly oriented toward emerging domains such as AI security and adversarial machine learning, cloud and hybrid architecture protection, cyber resilience, Zero Trust architectures, digital supply-chain defense, and governance, risk, and compliance (GRC). These topics reflect a forward-looking strategic posture aligned with global trends. At the same time, qualitative data reveal interest in more specialized areas including post-quantum cryptography, operational technology security, digital forensics, privacy engineering, and cybersecurity policy indicating that institutions are preparing for a rapidly evolving threat landscape that demands interdisciplinary competencies and governance-based approaches. These insights can inform national cybersecurity strategies, workforce training programs, and regulatory modernization efforts within Brazil's digital ecosystem.

Future work may advance this study in several directions. First, expanding the dataset to a larger and more diverse sample including small and medium-sized enterprises (SMEs), municipalities, and underrepresented sectors would enhance external validity and enable sector-specific comparative analyses. In particular, future research should explicitly investigate how cybersecurity risks, development practices, and governance challenges manifest in SMEs, which often operate under resource constraints and exhibit different maturity levels compared to large organizations. Such analyses would allow a more nuanced understanding of contextual differences and improve the generalizability of findings across heterogeneous organizational settings.

Second, longitudinal studies could capture how organizational maturity, regulatory pressure, and technology adoption evolve over time, particularly

regarding AI enabled security operations and DevSecOps practices. Third, integrating quantitative correlation analyses, structural modeling, or cluster analyses would offer deeper insights into relationships between organizational attributes, risk perceptions, and capability gaps. Finally, future studies could operationalize and evaluate competency frameworks, training programs, and governance models especially those related to AI security, supply-chain resilience, and privacy engineering to assess their practical effectiveness in strengthening institutional cybersecurity readiness.

These findings reinforce the need for integrated governance strategies, continuous workforce development, and resilient security practices capable of addressing increasingly complex and evolving cybersecurity environments.

Acknowledgments

The authors are deeply grateful to all practitioners who contributed to this work by responding to our surveys. This study was financed in part by the National Council for Scientific and Technological Development (CNPq) under Grants No. 300883/2025-0 and No. 406266/2025-5.

References

- [1] Abdulrahman, A., Richards, D., Bilgin, A.A., Formosa, P., 2026. Developing ethical principle awareness and reasoning in a cybersecurity context: Enhancing user understanding using ripple down rules. *Computers & Security* 161, 104761. doi:<https://doi.org/10.1016/j.cose.2025.104761>.
- [2] Akbar, M.A., AlSanad, A.A., 2025. Empirical investigation of key enablers for secure devops practices. *IEEE Access* 13, 43698–43715. doi:10.1109/ACCESS.2025.3549183.
- [3] Akbar, M.A., Smolander, K., Mahmood, S., Alsanad, A., 2022. Toward successful devsecops in software development organizations: A decision-making framework. *Information and Software Technology* 147, 106894. URL: <https://www.sciencedirect.com/science/article/pii/S0950584922000568>, doi:<https://doi.org/10.1016/j.infsof.2022.106894>.

- [4] Andrade, R., Filho, G.R., Marques, G., Canedo, E., 2026. Privacy, data protection, risk, and compliance in the age of generative ai systems: A systematic mapping study, in: Anais do XXII Simpósio Brasileiro de Sistemas de Informação, SBC, Porto Alegre, RS, Brasil. pp. 1181–1200. URL: <https://sol.sbc.org.br/index.php/sbsi/article/view/41374>, doi:10.5753/sbsi.2026.248735.
- [5] Barrett, M.P., 2018. Framework for Improving Critical Infrastructure Cybersecurity Version 1.1. Technical Report NIST.CSWP.04162018. NIST Cybersecurity Framework. URL: <https://doi.org/10.6028/NIST.CSWP.04162018>, doi:10.6028/NIST.CSWP.04162018.
- [6] Carello, M.P., 2025. Enhancing cybersecurity framework adoption: methodologies and techniques for contexts specific implementations. Ph.D. thesis. Sapienza University of Rome, Italy. URL: <https://hdl.handle.net/11573/1733380>.
- [7] Caviglia, R., 2025. Novel Approaches to Standard Based Cybersecurity Risk Management in OT Environment. Ph.D. thesis. University of Genoa, Italy. URL: <https://hdl.handle.net/11567/1242175>.
- [8] Cheenepalli, J., Hastings, J.D., Ahmed, K.M., Fenner, C., 2025. Advancing devsecops in smes: Challenges and best practices for secure ci/cd pipelines, in: 2025 13th International Symposium on Digital Forensics and Security (ISDFS), pp. 1–6. doi:10.1109/ISDFS65363.2025.11011960.
- [9] Ebert, N., Schaltegger, T., Ambuehl, B., Schöni, L., Zimmermann, V., Knieps, M., 2023. Learning from safety science: A way forward for studying cybersecurity incidents in organizations. *Comput. Secur.* 134, 103435. URL: <https://doi.org/10.1016/j.cose.2023.103435>, doi:10.1016/J.COSE.2023.103435.
- [10] ENTERPRISE, I.P.T., April 14, 2025. Nist privacy framework: A tool for improving privacy through enterprise risk management, version 1.1. National Institute of Standards and Technology doi:<https://doi.org/10.6028/NIST.CSWP.40.ipd>.
- [11] Glas, M., Hilmer, C., Pernul, G., 2025. Cyber ranges: Five use cases for improving cybersecurity skills development in organizations. *IEEE*

- Secur. Priv. 23, 69–78. URL: <https://doi.org/10.1109/MSEC.2025.3596735>, doi:10.1109/MSEC.2025.3596735.
- [12] Haren, J., Leahy, M., Donlon, E., 2024. Continuing professional development among cybersecurity professionals in Ireland: A qualitative study, in: 2024 Cyber Research Conference - Ireland (Cyber-RCI), pp. 1–8. URL: <https://ieeexplore.ieee.org/document/10939367>, doi:10.1109/Cyber-RCI60769.2024.10939367.
- [13] Hasan, S., Ali, M., Kurnia, S., Thurasamy, R., 2021. Evaluating the cyber security readiness of organizations and its influence on performance. *Journal of Information Security and Applications* 58, 102726. URL: <https://www.sciencedirect.com/science/article/pii/S2214212620308656>, doi:<https://doi.org/10.1016/j.jisa.2020.102726>.
- [14] Hoong, Y., Rezania, D., 2024. Navigating cybersecurity governance: The influence of opportunity structures in socio-technical transitions for small and medium enterprises. *Comput. Secur.* 142, 103852. URL: <https://doi.org/10.1016/j.cose.2024.103852>, doi:10.1016/J.COSE.2024.103852.
- [15] Ilari, L., Tiribelli, S., Caruso, F., 2026. From AI security to ethical AI security: a comparative risk-mitigation framework for classical and hybrid AI governance. *AI Ethics* 6, 91. URL: <https://doi.org/10.1007/s43681-025-00935-x>, doi:10.1007/S43681-025-00935-X.
- [16] Kitchenham, B.A., Madeyski, L., 2024. Recommendations for analysing and meta-analysing small sample size software engineering experiments. *Empir. Softw. Eng.* 29, 137. URL: <https://doi.org/10.1007/s10664-024-10504-1>, doi:10.1007/S10664-024-10504-1.
- [17] Kitchenham, B.A., Pfleeger, S.L., 2002. Principles of survey research: part 5: populations and samples. *ACM SIGSOFT Softw. Eng. Notes* 27, 17–20. URL: <https://doi.org/10.1145/571681.571686>, doi:10.1145/571681.571686.
- [18] Kitchenham, B.A., Pfleeger, S.L., 2008. Personal opinion surveys, in: *Guide to advanced empirical software engineering*. Springer, pp. 63–92. URL: https://doi.org/10.1007/978-1-84800-044-5_3.

- [19] Kunicina, N., Zabasta, A., Krumins, O., Romanovs, A., Patlins, A., 2020. Cybersecurity curricula recommendations development for technical background and engineering skills in international dimension, in: 2020 IEEE 61th International Scientific Conference on Power and Electrical Engineering of Riga Technical University (RTUCON), pp. 1–6. doi:10.1109/RTUCON51174.2020.9316573.
- [20] Macedo, P.N., 2018. Brazilian general data protection law (lgpd). Nartional Congress, accessed in October 18, 2019 URL: <https://www.pnm.adv.br/wp-content/uploads/2018/08/Brazilian-General-Data-Protection-Law.pdf>.
- [21] Marotta, A., Madnick, B.F., Madnick, S.E., 2023. Navigating the wave of cybersecurity regulations: A systematic analysis of emerging regulatory developments, in: Pavlou, P.A., Midha, V., Animesh, A., Carte, T.A., Graeml, A.R., Mitchell, A. (Eds.), 29th Americas Conference on Information Systems, AMCIS 2023, Panama City, Panama, August 10-12, 2023, Association for Information Systems. pp. 1–11. URL: https://aisel.aisnet.org/amcis2023/sig_sec/sig_sec/12.
- [22] Matos, A., Patrício, M., Nicolau, M.I., Canedo, E.D., Pereira, J.A., Uchôa, A.G., 2025. Data privacy in software practice: Brazilian developers' perspectives. J. Internet Serv. Appl. 16, 299–319. URL: <https://doi.org/10.5753/jisa.2025.5302>, doi:10.5753/JISA.2025.5302.
- [23] de Mello, R.M., Travassos, G.H., 2016. Surveys in software engineering: Identifying representative samples, in: Proceedings of the 10th ACM/IEEE International Symposium on Empirical Software Engineering and Measurement, ESEM 2016, Ciudad Real, Spain, September 8-9, 2016, ACM. pp. 55:1–55:6. URL: <https://doi.org/10.1145/2961111.2962632>, doi:10.1145/2961111.2962632.
- [24] Menegazzi, D., Canedo, E., 2026. Privacy risks associated with the use of llms in software development, in: Anais do XXII Simpósio Brasileiro de Sistemas de Informação, SBC, Porto Alegre, RS, Brasil. pp. 201–215. URL: <https://sol.sbc.org.br/index.php/sbsi/article/view/41323>, doi:10.5753/sbsi.2026.248323.
- [25] Mirtaheri, S.L., Movahed, N., Shahbazian, R., Pascucci, V., Pugliese, A., 2026. Cybersecurity in the age of generative AI: A systematic taxonomy

- of ai-powered vulnerability assessment and risk management. *Future Gener. Comput. Syst.* 175, 108107. URL: <https://doi.org/10.1016/j.future.2025.108107>, doi:10.1016/J.FUTURE.2025.108107.
- [26] Noor, A.F.M., Moghavvemi, S., Tajudeen, F.P., 2025. Identifying key factors of cybersecurity readiness in organizations: Insights from malaysian critical infrastructure. *Comput. Secur.* 159, 104674. URL: <https://doi.org/10.1016/j.cose.2025.104674>, doi:10.1016/J.COSE.2025.104674.
- [27] OWASP, 2025. Owasp top 10 vulnerabilities. [owasp.org](https://owasp.org/www-project-top-ten/) URL: <https://owasp.org/www-project-top-ten/>.
- [28] Parkar, S., Mishra, D.K., 2024a. Cybersecurity workforce development and training: A comprehensive review on the significance, strategies, opportunities and challenges. 2024 International Conference on Intelligent Systems for Cybersecurity (ISCS) , 1–5URL: <https://api.semanticscholar.org/CorpusID:271116489>.
- [29] Parkar, S., Mishra, D.K., 2024b. Cybersecurity workforce development and training: A comprehensive review on the significance, strategies, opportunities and challenges, in: 2024 International Conference on Intelligent Systems for Cybersecurity (ISCS), pp. 1–5. URL: <https://ieeexplore.ieee.org/document/10581241>, doi:10.1109/ISCS61804.2024.10581241.
- [30] Petrová, K., Spatenka, J., Vaclavik, L., 2024. Assessment of cybersecurity of organizations: An empirical study of czech and slovak organizations. *Journal of Eastern European and Central Asian Research (JEECAR)* 11, 668–682. URL: <https://ieeca.org/journal/index.php/JEECAR/article/view/1666>.
- [31] Qawasmeh, S.A., AlQahtani, A.A.S., Khan, M.K., 2025. Navigating cybersecurity training: A comprehensive review. *Comput. Electr. Eng.* 123, 110097. URL: <https://doi.org/10.1016/j.compeleceng.2025.110097>, doi:10.1016/J.COMPELECENG.2025.110097.
- [32] Rattanapong, P., Sukma, N., Ayuthaya, S.D.N., 2025. Determinants of cybersecurity investment in ASEAN organizations: an integrated structural equation modeling approach. *Frontiers Commun.*

- Networks 6. URL: <https://doi.org/10.3389/frcmn.2025.1594554>, doi:10.3389/FRCMN.2025.1594554.
- [33] Shahid, A.R.B., Imteaj, A., 2025. Sticks and stones may break my bones, but words will never hurt me! - navigating the cybersecurity risks of generative AI. *AI Soc.* 40, 1529–1530. URL: <https://doi.org/10.1007/s00146-024-01934-y>, doi:10.1007/S00146-024-01934-Y.
- [34] Sharma, P., 2026. Secure software and application vulnerabilities in modern devsecops environments: A comprehensive analysis of security challenges, strategies, and future trends. *Journal of Computer, Internet and Network Security* ISSN: 2457-0176 (Online) 10. URL: <https://admin.mantechpublications.com/index.php/JoCINS/article/view/3020>.
- [35] Sinan, M., Shahin, M., Gondal, I., 2025. Integrating security controls in devsecops: Challenges, solutions, and future research directions. *J. Softw. Evol. Process.* 37. URL: <https://doi.org/10.1002/smr.70029>, doi:10.1002/SMR.70029.
- [36] for Standardization (ISO), I.O., 2022. Iso/iec 27001:2022: Information security, cybersecurity and privacy protection — information security management systems — requirements. URL: <https://www.iso.org/standard/27001>.
- [37] of Standards, N.I., NIST, T., 2023. Artificial intelligence risk management framework (ai rmf 1.0). NIST AI 100-1 , 1–48URL: <https://doi.org/10.6028/NIST.AI.100-1>.
- [38] Türegün, N., 2025. Digital transformation and cybersecurity risks. *Int. J. Account. Inf. Syst.* 56, 100749. URL: <https://doi.org/10.1016/j.accinf.2025.100749>, doi:10.1016/J.ACCINF.2025.100749.
- [39] Wei, W., Li, X., Tanriverdi, H., 2025. Privacy, utility, and cybersecurity risks of software generation by large language models. Available at SSRN 5309446 , 1–48URL: <http://dx.doi.org/10.2139/ssrn.5309446>.
- [40] Wohlin, C., Runeson, P., Höst, M., Ohlsson, M.C., Regnell, B., Wesslén, A., 2012. *Experimentation in Software Engineering*. Springer. URL: <https://doi.org/10.1007/978-3-642-29044-2>, doi:10.1007/978-3-642-29044-2.

- [41] Zhou, X., Mao, R., Zhang, H., Dai, Q., Huang, H., Shen, H., Li, J., Rong, G., 2023. Revisit security in the era of devops: An evidence-based inquiry into devsecops industry. URL: <https://ietresearch.onlinelibrary.wiley.com/doi/abs/10.1049/sfw2.12132>.

Declaration of interests

☒ The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

☐ The authors declare the following financial interests/personal relationships which may be considered as potential competing interests: